

Project 4 -

- Mobile ransomware

Delivery- **Permission Abuse**: The top two mobile OSes today, Android and iOS, both use permission-based access control. Applications are required to be granted necessary permissions before being allowed to execute certain actions. In the Android framework, permissions are largely related to system features such as accessibility services and accessing personal data. App developers are required to specify what permissions their application needs, with users being asked to approve these permissions before the app runs.

This means that during the installation of malware, malicious actors would still need to procure the permissions required by their malware to carry out its exploits. Targets with poor cyber hygiene (operational security habits) who do not make it a habit to check requested permissions before installing apps will likely end up being victims.

Social Engineering: Social media and messaging apps are a popular malware delivery channel used to carry out social engineering attacks. Victims can be tricked into downloading trojanized applications through psychological manipulation.

Trojan-Dropper: Trojan droppers are seemingly innocent applications that 'drop' malicious applications by executing code. The code either decrypts and executes a malicious payload within, or downloads and installs malware from an external server. The use of trojan droppers has become increasingly common among cybercriminals. Anubis and Agent Smith are just some recent examples of successful and widely spread malware that have been found to utilize trojan droppers.

ScarePackage: The infamous ScarePackage ransomware attack reached over 900,000 Android users in just 30 days.

Victims downloaded what appeared to be anti-virus software that would scan their devices, but was actually installing ransomware. Once complete, victims received some variation of a message accusing them of heinous offenses, such as distributing illicit materials or sending out bulk spam. The ransomware message claims that the FBI has locked the user's phone and that the only way to unlock it is to pay a fee.

Mitigations: **Install security patches**. Ransomware typically makes its way onto a device via a download. Sometimes these downloads occur by visiting compromised websites. You can avoid them by installing and updating the latest security patches.

Back up all files. By backing up your files in a third-party cloud that's unconnected to the rest of your business, you can reduce the cost and risk of ransomware.

Stay informed. Ransomware is anything but static. New attacks, methods, and software are being developed on a daily basis. It's imperative that you stay informed so that you know how to best protect your business, employees, and devices.

The device can be unlocked by booting it to safe mode, then removing the application that locks the device.

1. Attacker will create a malicious script, Encrypting data and Locking the user out of their devices.
2. The malicious script then can be hidden in an application available for download from the app store.
3. Victims download the app or are instructed to download the app with the malware.
4. After downloading the app will install and run
5. The ransomware attack is complete, with the user's data encrypted and the phone locked out displaying a message asking them to pay the ransom on the lock screen.

8:57



YOUR PHONE IS ENCRYPTED: YOU HAVE 48 HOURS TO PAY 100\$ in BITCOIN OR EVERYTHING WILL BE ERASED

1. What will be deleted? your contacts, your pictures and videos, all social media accounts will be leaked publicly and the phone memory will be completely erased
2. How to save it? you need a decryption code that will disarm the app and unlock your data back as it was before
3. How to get the decryption code? you need to send the 100\$ in bitcoin to the adress below, click the button below to see the code

NOTE: YOUR GPS IS WATCHED AND YOUR LOCATION IS KNOWN, IF YOU TRY ANYTHING STUPID YOUR PHONE WILL BE AUTOMATICALLY ERASED

Web Designius

enter decryption code

DECRYPT

Regular back-up, this is crucial. If mobile ransomware happens you can simply wipe your phone and restore the previous back-up.

OPEN REDIRECT

`mysite.com/open?url=mysite.com/home`

Security training that covers ransomware to Employees.

- training that covers what ransomware is, how these attacks start (usually through phishing emails), and what to do if they suspect a potential attack. All employees should know what to do if they receive a suspicious email.

Conduct regular vulnerability scanning to identify and address vulnerabilities

- especially those on internet-facing devices, to limit the attack probability

Regular patch and update software and OS to the latest version

- Prioritize timely patching of internet-facing servers—that operate software for processing internet data, such as web browsers, browser plugins, and document readers

Having an incident response plan in place to minimize the impact of an attack

Regular backups

- Set up redundant backups and secure them properly. Whenever possible, automatically schedule data backups.